

Post-Quantum Readiness for AI Agent Identity

A whitepaper from AI Identity · May 2026

How AI Identity designed its agent credentials, audit chains, and mandate signatures for the NIST post-quantum standards — and the migration path we're shipping through 2027.

Executive summary

The NIST post-quantum cryptography standards (FIPS 203, 204, and 205) are finalized. Federal agencies and regulated industries now face a measurable migration window: cryptography deployed today must be re-evaluated against a 5–10 year quantum threat horizon. For AI agent infrastructure — where credentials, audit trails, and signed capabilities form the trust spine of autonomous systems — that window opens earlier than most organizations have planned for.

AI Identity has designed its agent identity, audit, and mandate primitives with explicit algorithm slots for ML-DSA-87 alongside the classical ECDSA-P256 we use today. This whitepaper documents where cryptography lives in the platform, the hybrid-signing path we're shipping through Q4 2026, and the migration plan to PQ-native agent credentials by Q3 2027.

The intended audience is platform engineering, security architecture, and compliance leadership at regulated industries evaluating AI agent deployments — particularly in federal, financial services, and healthcare verticals where the quantum-readiness conversation is now an active procurement question.

1. The quantum threat to AI agent identity

The conversation about post-quantum cryptography has matured beyond "if" into "when, and what do we do until then." Three developments make this concrete:

- 1. NIST finalized the first post-quantum standards in August 2024.** FIPS 203 (ML-KEM, formerly Kyber) for key encapsulation, FIPS 204 (ML-DSA, formerly Dilithium) for digital signatures, and FIPS 205 (SLH-DSA, formerly SPHINCS+) for stateless hash-based signatures. These are not drafts; they are the standards.
- 2. Federal procurement is moving.** OMB M-23-02 and CNSA 2.0 frame post-quantum migration as an active 2025–2030 program, not a research project. Regulated buyers in financial services and healthcare are starting to ask the same questions during vendor security reviews.
- 3. "Harvest now, decrypt later" is a credible threat model for high-value, long-lived data.** Even if a cryptographically relevant quantum computer is five to ten years out, encrypted communications and signed artifacts that are intercepted and archived today become vulnerable retroactively the day that machine exists.

For an AI agent identity platform, the surface area to protect is specific:

- **Agent credentials.** Long-lived public-key bindings that prove a given API call came from a specific autonomous agent. If those bindings are forgeable in the future, every audit trail signed against them becomes deniable.
- **Audit chains.** Tamper-evident hash chains that prove a sequence of agent decisions actually happened in the order recorded. If the signature algorithm is broken, the chain stops being evidence.
- **Mandate signatures.** Signed capability grants that authorize an agent to take a specific action under specific conditions. A forgeable mandate is an unbounded permission.

None of these can be patched into post-quantum readiness after the fact without invalidating every artifact issued before the migration. The design has to be ready first, then the algorithms can rotate.

2. Where cryptography lives in AI Identity today

Before describing the migration, here is what AI Identity uses cryptography for today and which algorithm is in use.

Primitive	Purpose	Today	Designed slot for
Agent credential signature (aid_sk_*)	Prove an API call originates from a specific registered agent identity	ECDSA-P256	ML-DSA-87
Audit chain link signature	Bind each agent decision to the previous, tamper-evident	HMAC-SHA256	SLH-DSA (stateless hash-based, FIPS 205)
Mandate signature	Authorize a specific capability grant to an agent	ECDSA-P256	ML-DSA-87
Inter-service auth (control plane → gateway)	Service-to-service identity within the platform	mTLS with ECDSA certs	Hybrid X.509 with ML-DSA
Webhook receipt verification	Confirm webhook delivery integrity to customer endpoints	HMAC-SHA256	(no change planned — HMAC is symmetric, not quantum-vulnerable for short-lived secrets)

The audit chain currently uses HMAC-SHA256 rather than a public-key signature. Grover's algorithm halves the effective security of symmetric primitives in the quantum-adversary model, so HMAC-SHA256 retains ~128-bit security against a quantum attacker — still defensible for short-lived audit attestations but weaker than the asymmetric path. We are migrating the audit chain to SLH-DSA precisely because the chain itself is high-value, long-lived evidence: customers should be able to replay an audit trail in 2030 against the keys that signed it in 2026 without trusting that the signature algorithm is still intact.

3. The crypto-agility design

The Mandate Service was the first AI Identity primitive built with explicit crypto-agility from the first commit. Two design choices make the migration possible without a future signature rewrite:

Algorithm slots, not algorithm assumptions. Every signed artifact in AI Identity — credentials, mandates, audit chain links — carries an explicit algorithm identifier alongside the signature itself. Verification code dispatches on that identifier. Adding ML-DSA-87 to the list is a code change, not a schema change.

Dual-signature envelopes. The hybrid signing path stores both a classical signature (ECDSA-P256) and a post-quantum signature (ML-DSA-87) on the same artifact during the transition window. Verifiers can accept either, depending on their compliance posture; once enough verifier code has rolled out, the classical signature can be retired without re-issuing every credential.

No buried algorithm assumptions in storage. Mandate and credential records in MongoDB Atlas carry the full signature envelope, including algorithm metadata. There are no SQL columns sized for a specific signature length. ML-DSA-87 signatures are roughly 4.6 KB — about 70× the size of an ECDSA-P256 signature — and the schema accommodates that without migration.

This is not novel cryptography. It is the same hybrid envelope pattern that the IETF post-quantum migration drafts (`draft-ietf-tls-hybrid-design`, `draft-ounsworth-pq-composite-sigs`) advocate for TLS and X.509. We just applied it to the artifact types specific to AI agent identity earlier than most identity platforms have.

4. Hybrid signing: ECDSA-P256 + ML-DSA-87

The first PQ migration step shipping in 2026 is hybrid signing on agent credentials and mandates. The verification semantics are deliberately conservative.

Issuance. When a new credential or mandate is issued, AI Identity generates a fresh ECDSA-P256 keypair and a fresh ML-DSA-87 keypair, signs the payload with both, and stores both signatures inside the artifact envelope.

Verification. A relying party can verify either signature. The default policy is **classical-AND-post-quantum** — both signatures must be valid for the artifact to be accepted. Customers in regulated environments who require the strongest posture can configure their verifier in this mode from day one. Customers with mixed-environment verifiers can run **classical-OR-post-quantum** during the transition window, accepting whichever signature their verifier supports.

Why ML-DSA-87 and not ML-DSA-44 or ML-DSA-65. The NIST levels correspond to roughly AES-128, AES-192, and AES-256 quantum-classical equivalents. ML-DSA-87 (NIST level 5, ~AES-256) matches the security level federal procurement is moving toward for long-lived signatures. For short-lived authentication tokens we expect to ship ML-DSA-65 (level 3) as a configurable option. The default for a credential that may live a year or more is the higher level.

Why not SLH-DSA for credentials. SLH-DSA signatures are an order of magnitude larger than ML-DSA-87 (~17 KB vs ~4.6 KB) and significantly slower to verify. For high-volume credential verification on the gateway hot path, ML-DSA-87 is the right tradeoff. SLH-DSA is reserved for the audit chain, where signatures are

produced less frequently and verified by humans or auditors rather than by every inbound gateway request.

5. Migration roadmap

The migration is staged. Each phase ships a capability that is independently testable, and each phase preserves backward compatibility with the prior one. Internal milestone IDs reference the CEO Dashboard for traceability.

Phase	Window	Deliverable	Verifier requirement
Audit	Q3 2026	Complete inventory of every ECDSA/RSA/HMAC usage in gateway, audit chain, mandate, and credential paths. Published as appendix to this whitepaper.	None — internal artifact
Hybrid signing live	Q4 2026	ECDSA-P256 + ML-DSA-87 dual signatures on every new credential and mandate. Verifier libraries updated to accept both.	Customers on AI Identity SDK $\geq$ v2.4 get hybrid verification automatically. Earlier SDKs continue to verify the classical signature.
PQ audit chain	Q1 2027	SLH-DSA hash-chained audit links alongside HMAC. Audit chain replay tool updated to verify both.	None for customers — chain verification stays inside AI Identity. Regulators and auditors run the open verification CLI.
PQ-native credentials	Q3 2027	New credential issuance defaults to ML-DSA-87 only (no classical signature). Existing dual-signed credentials remain valid through their natural rotation cycle.	Customer verifiers must be on SDK $\geq$ v2.4. ECDSA-only verification is deprecated.
Classical retirement	2028+	Decision gated on real-world quantum threat posture. We do not pre-commit a date — the conservative migration windows are not predictions, they are floors.	TBD

The dates above are derived from internal milestones (audit $\approx$ Milestone #45 target; hybrid signing live = Milestone #45 deliverable on 2026-12-31; PQ audit chain and PQ-native credentials are sequenced through H2 2027). Updates to this roadmap will be reflected in subsequent versions of this whitepaper.

6. What this means for regulated buyers

A few specific things this design buys for organizations procuring AI agent infrastructure:

Federal procurement readiness. FedRAMP authorization and CNSA 2.0 alignment are forthcoming requirements for any federal-adjacent AI deployment. Vendors who have not begun the migration in 2026 are unlikely to be on the right side of the procurement question by 2028. AI Identity has begun.

Financial sector signature longevity. NYDFS 23 NYCRR 500 and SEC Rule 17a-4 audit retention requirements are measured in years. Audit artifacts signed today need to remain verifiable for the full retention window. SLH-DSA-signed audit chains protect that retention horizon without requiring re-signing on algorithm change.

EU AI Act technical documentation. Article 12 and Article 13 of the EU AI Act require traceable, tamper-evident records of high-risk AI system decisions. The Mandate Service plus PQ-ready audit chain produce exactly that record type — regulator-verifiable independent of vendor cooperation.

No "rip and replace" risk. Customers integrating with AI Identity today, with classical-only ECDSA-P256 signatures, will not face a migration cliff. The same credential and mandate envelopes that work today will keep working through the hybrid window. Verification clients pick up the additional signature when they're ready to verify it.

7. About AI Identity

AI Identity is the identity, policy, compliance, and forensic infrastructure layer for AI agents. The platform issues per-agent cryptographic credentials, enforces context-aware policy at a fail-closed gateway, produces tamper-evident audit chains, and signs capability grants through the Mandate Service.

Headquarters: Boulder, Colorado. Stage: design partner. Category: Agent IAM + Audit.

To talk to us about post-quantum readiness in your AI agent deployment — federal, financial, or healthcare contexts especially — start at ai-identity.co/pqc-readiness or reach the founder directly through the contact form on ai-identity.co/about.

Appendix A: Glossary

- **ML-KEM** (FIPS 203, formerly Kyber): Key encapsulation mechanism. Used for key agreement, not signatures.
- **ML-DSA** (FIPS 204, formerly Dilithium): Lattice-based digital signature algorithm. Levels 44, 65, 87 correspond to NIST security levels 2, 3, 5.
- **SLH-DSA** (FIPS 205, formerly SPHINCS+): Stateless hash-based signature algorithm. Larger and slower than ML-DSA; well-suited to long-lived signatures with infrequent verification.
- **Hybrid signature:** Two signatures on the same payload, one classical (e.g., ECDSA), one post-quantum (e.g., ML-DSA). Allows transition without invalidating either path.

- **Crypto-agility:** A system property: the ability to change the cryptographic algorithm in use without changing the surrounding protocol, schema, or storage format.
- **Harvest now, decrypt later (HNDL):** An adversary model in which encrypted material captured today is stored for future decryption against a cryptographically relevant quantum computer.